SISTEMI E RETI · SICUREZZA INFORMATICA

Difendersi: le contromisure

Dagli attacchi alle difese: che cosa fa davvero un'azienda, una scuola o una persona per proteggersi.

L'IDEA DI FONDO

Difesa in profondità: più strati, non un muro solo

Strato	Contromisure
Persone	Formazione, regole chiare, segnalazione degli incidenti
Accessi	Password manager, MFA, minimo privilegio
Dispositivi	Aggiornamenti, antivirus ed EDR, cifratura del disco
Rete	Firewall, HTTPS, VPN
Applicazioni	Query parametrizzate, validazione dell'input
Dati	Backup 3-2-1, cifratura

> Se uno strato cede, il successivo limita il danno. E quando cedono tutti serve un **piano di risposta**.

STRATO ACCESSI

Password manager e autenticazione a più fattori

Password manager

- Ricordi **una sola** password principale, lunga e robusta.
- Genera password lunghe e **diverse per ogni sito**.
- Compila i campi solo sul sito giusto: aiuta anche contro il phishing.

MFA

- La password rubata da sola **non basta** più.
- Meglio app di autenticazione o chiavette che SMS.
- Mai approvare una richiesta di accesso che non hai fatto tu.

Contro: forza bruta, dizionario, **credential stuffing**, buona parte del phishing.

STRATO DISPOSITIVI

Aggiornare e sorvegliare

Aggiornamenti

Ogni patch chiude una vulnerabilità **già nota** anche agli attaccanti. Aggiornamenti automatici su PC, telefono, router, plugin.

Antivirus

Riconosce i malware noti dalla loro **firma** e quelli nuovi da comportamenti sospetti. In Windows c'è Microsoft Defender.

EDR

Endpoint Detection and Response: sorveglia ciò che succede sul PC, dà l'allarme e può isolarlo dalla rete.

Esempio: un programma che rinomina centinaia di file al minuto. L'antivirus può non conoscerlo, l'EDR nota il **comportamento** da ransomware.

STRATO RETE

Il firewall decide quale traffico passa

Traffico	Servizio	Azione
In uscita	`443 · HTTPS`	Consenti
In ingresso da Internet	`3389 · Desktop remoto`	Blocca
In ingresso, non richiesto	`qualsiasi`	Blocca

Le regole guardano direzione, indirizzi, porte e programmi.

Firewall del PC

Protegge il singolo computer. In Windows è attivo di serie.

Firewall di rete

Sta tra la rete interna e Internet e protegge tutti.

> Il firewall non ferma ciò che passa per una porta consentita: una mail di phishing arriva lo stesso.

AL COMPUTER · 15 minuti

Com'è protetto il tuo PC?

1. Dal menu Start apri **Sicurezza di Windows**.
2. In **Protezione da virus e minacce** annota se la protezione è attiva e la data dell'ultimo aggiornamento.
3. In **Firewall e protezione della rete** annota lo stato delle reti di dominio, private e pubbliche.
4. Apri **PowerShell** (non come amministratore) ed esegui i due comandi qui a destra.
5. Salva tutto in **stato-sicurezza-Cognome.txt**. Non modificare nessuna impostazione.

```
Get-NetFirewallProfile |
  Format-Table Name, Enabled

Get-MpComputerStatus |
  Select-Object RealTimeProtectionEnabled,
  AntivirusSignatureLastUpdated
```

Controllo: trovi tre profili (Domain, Private, Public), ciascuno con `True` o `False`.

STRATO DATI

La regola del backup 3-2-1

3

copie dei dati

L'originale più due copie di sicurezza.

2

supporti diversi

Per esempio un NAS e un disco esterno, o un NAS e il cloud.

1

copia fuori sede

Lontana dall'ufficio: un incendio o un furto non la toccano.

Contro il ransomware almeno una copia deve essere **scollegata** o non modificabile. E un backup vale solo se hai **provato a ripristinarlo**.

AL COMPUTER · 20 minuti

Progetta il backup di uno studio

Il cliente

Uno studio di commercialisti: 5 PC, un NAS in ufficio con circa 300 GB di documenti dei clienti e il programma di contabilità. Lavorano dal lunedì al sabato.

1. In Calc crea le colonne **Copia · Dove · Supporto · Frequenza · Chi controlla**.
2. Compila una riga per ogni copia, originale compreso.
3. Aggiungi sotto quando e come si prova il ripristino.
4. Salva come **backup-Cognome.ods**.

Controllo: ci sono 3 copie su almeno 2 supporti, 1 fuori sede, almeno una scollegata o non modificabile, e le copie fuori ufficio sono cifrate.

RISERVATEZZA DEI DATI

Cifratura: in viaggio e a riposo

Dati in transito

- **HTTPS** cifra la comunicazione con il sito: il lucchetto nel browser.
- Rende inutile l'intercettazione del **man-in-the-middle**.
- Su reti sconosciute si può aggiungere una **VPN**.

Dati a riposo

- Disco cifrato: **BitLocker** in Windows, FileVault in macOS.
- I telefoni sono cifrati quando c'è un codice di sblocco.
- Se rubano il portatile, i dati restano illeggibili.

HTTPS non dice che il sito è onesto: dice solo che la connessione con **quel** sito è cifrata. Anche i siti di phishing hanno il lucchetto.

STRATO ACCESSI

Minimo privilegio: solo i permessi che servono

Ogni utente e ogni programma riceve **soltanto** i permessi indispensabili, per il tempo necessario.

Sul PC

Si lavora con un account **standard**; quello da amministratore si usa solo per installare.

Nel database

L'applicazione web usa un utente che può leggere e scrivere le sue tabelle, non cancellare il database.

In azienda

Permessi per ruolo, rivisti spesso. Chi cambia lavoro o se ne va perde subito gli accessi.

> Non impedisce l'attacco, ma ne **limita i danni**: un malware ha solo i permessi di chi l'ha avviato.

STRATO APPLICAZIONI

Query parametrizzate e validazione dell'input

Prima: il dato diventa parte del comando.

```
sql = "... WHERE cognome = '" + cognome + "'"
db.execute(sql)
```

Dopo: il comando ha un segnaposto `?`, il dato viaggia a parte.

```
sql = "... WHERE cognome = ?"
db.execute(sql, (cognome,))
```

Validazione dell'input

Controlla tipo, lunghezza e formato. Meglio elencare ciò che è **ammesso** che ciò che è vietato.

Escaping dell'output

Prima di mettere un testo in una pagina, `<` e `>` diventano `<` e `>`: contro l'XSS.

AL COMPUTER · 20 minuti

Correggi il codice della lezione scorsa

```
3  sql = "SELECT nome, classe FROM studenti WHERE cognome = '" + cognome + "'"
4  righe = db.execute(sql).fetchall()
5  html = "<h3>Risultati per " + cognome + "</h3>"
```

1. Apri il Blocco note o l'editor del laboratorio e riscrivi le righe 3 e 4 con una query parametrizzata.
2. Riscrivi la riga 5 usando `html.escape(cognome)` (serve `import html` : rinomina la variabile in `pagina`).
3. Salva come **cerca_sicuro-Cognome.py**.

Controllo: nella query non c'è più nessun `+`, c'è un `?` e il valore è passato come `(cognome,)`. Se hai Python, cercando D'Amico non ottieni errori.

STRATO PERSONE

La formazione è una contromisura tecnica

Riconoscere

Gli indizi del phishing, le richieste insolite, i link e gli allegati sospetti.

Segnalare subito

Anche se hai già cliccato: avvisare dopo cinque minuti è meglio che dopo cinque giorni.

Allenarsi

Simulazioni di phishing periodiche, brevi e con spiegazione finale.

Regole chiare

Dove salvare i file, chi chiamare, che cosa non fare mai.

Chi segnala un proprio errore va **ringraziato**, non punito: altrimenti la prossima volta tace.

QUANDO TUTTO IL RESTO FALLISCE

Il piano di risposta agli incidenti

Preparazione
Ruoli, contatti, backup, procedure scritte prima.

→

Rilevamento
Capire che cosa è successo e quanto è grave.

→

Contenimento
Isolare i sistemi colpiti per fermare la diffusione.

→

Ripristino
Eliminare la causa, ripartire dai backup.

→

Lezioni apprese
Che cosa cambiamo?

Se sono coinvolti **dati personali**, il titolare deve valutare la notifica al Garante della privacy **entro 72 ore** (GDPR, art. 33).

AL COMPUTER · 20 minuti

Scrivi la checklist dell'incidente

Ore 10:15, segreteria

Sul PC di un'impiegata i file hanno un'estensione strana e non si aprono. Sul desktop c'è un messaggio che chiede un riscatto.

In Documenti Google crea **checklist-incidente-Cognome**: da 8 a 10 azioni in ordine, divise in **Subito · Entro oggi · Nei giorni seguenti**. Per ogni azione indica **chi** la fa.

Controllo: la prima azione isola il PC dalla rete; nessuno paga o cancella prove; c'è un passo sui dati personali (72 ore) e uno sulle lezioni apprese.

RIPASSO

Per ogni attacco, le sue difese

Attacco	Difese principali
Malware e ransomware	Aggiornamenti, antivirus ed EDR, minimo privilegio, backup 3-2-1
Phishing	Formazione, MFA, password manager
Attacchi alle password	Password lunghe e uniche, MFA
Man-in-the-middle	HTTPS, VPN, mai ignorare gli avvisi sui certificati
DoS e DDoS	Firewall, protezione anti-DDoS, ridondanza
SQL injection e XSS	Query parametrizzate, validazione, escaping
Zero-day	Difesa in profondità, aggiornamenti rapidi, piano di risposta